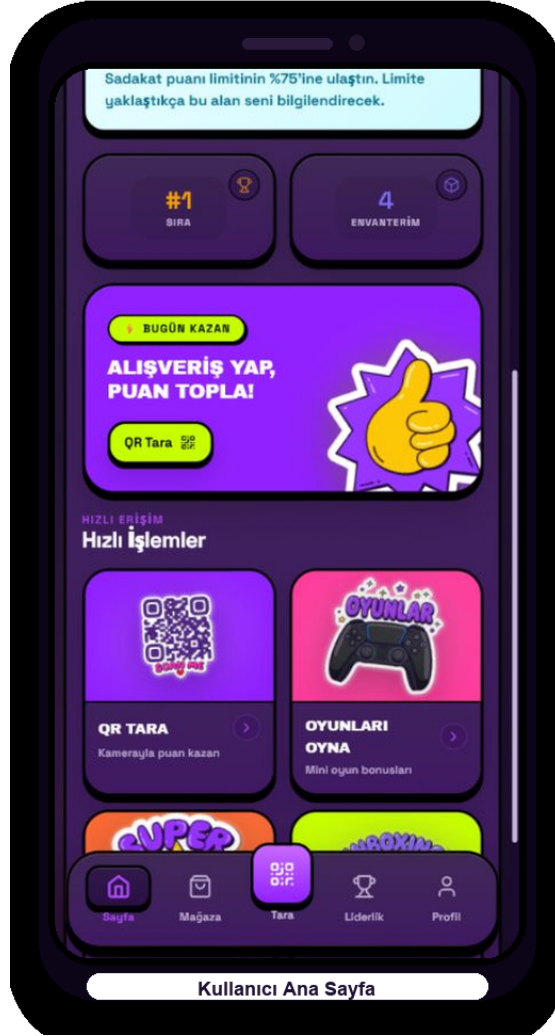


NEŞVENEXT

Sadakat, Ödül, QR ve Yönetim Platformu - Türkçe Kapsamlı Ürün ve Teknik Rapor

Rapor kapsamı

Bu rapor 29.06.2026 23:02 tarihinde proje kaynak kodu, Supabase migration dosyaları, servis katmanı ve mevcut uygulama ekran görüntüleri incelenerek hazırlanmıştır.



Telefon çerçeveli örnek uygulama görünümü

1. Yönetici Özeti

NeşveNext, müşterilerin alışveriş, QR kod, günlük giriş, mini oyun, görev ve etkinliklerden puan kazandığı; bu puanları ödül bileti ve kuponlara dönüştürdüğü bir sadakat platformudur. Sistem; kullanıcı uygulaması, kasiyer paneli, mağaza/admin yönetimi, gerçek zamanlı liderlik ve Supabase tabanlı güvenli iş mantığından oluşur.

- Kullanıcılar puan kazanır, XP ve seviye ilerlemesi yaşar, ödül mağazasından bilet alır ve envanterde QR/kod olarak gösterir.
- Kasiyerler alışveriş tutarına göre tek kullanımlık QR oluşturur ve müşterinin bilet/kupon kodunu manuel veya QR tarama ile teslim eder.
- Adminler kullanıcı, ödül, envanter, QR, günlük ödül, oyun, bildirim, etkinlik, puan ekonomisi ve genel ayarları yönetir.
- Supabase RLS, server-side RPC, role checks, tek kullanımlık QR ve bilet süre kontrolleri ile kötüye kullanım azaltılır.
- UI dili neo-brutalism + iPhone app hissi: kalın sınırlar, yuvarlatılmış kartlar, sticker görseller, büyük aksiyonlar ve mobil öncelikli akış.

2. Kullanılan Teknolojiler

Frontend

- React ^18.3.1 ve React DOM ^18.3.1: bileşen tabanlı kullanıcı arayüzü.
- Vite ^5.4.2: hızlı geliştirme, optimize production build ve modern bundle çıktısı.
- TypeScript ^5.5.3: tip güvenliği ve daha kontrollü servis katmanı.
- React Router DOM ^7.15.1: HashRouter ile route yönetimi.
- TanStack React Query ^5.74.4: cache, invalidation ve veri yenileme.
- Lucide React, Recharts, ZXing, jsQR, qrcode, lokal fontlar ve responsive CSS sistemi.

Backend ve Veritabanı

- Supabase JS ^2.108.1: Auth, PostgREST, Realtime ve Edge Functions bağlantısı.
- Supabase Auth: e-posta/şifre, Google OAuth, PKCE flow ve session persistence.
- PostgreSQL tabloları: profiles, rewards, redemptions, qr_codes, qr_scans, points_transactions, app_settings, games_config, daily_reward_config, event_participants.
- Security definer RPC fonksiyonları: claim_qr_scan, preview_qr_scan, purchase_reward, claim_daily_streak, lookup_redemption_by_code, mark_redemption_used_by_code, create_cashier_qr.
- Supabase Realtime: profil, puan, leaderboard ve envanter güncellemelerinde canlı yenileme.

Deployment ve Operasyon

- Vercel deployment: Vite dist çıktısı ve project/vercel.json ayarı.
- Environment değişkenleri: VITE_SUPABASE_URL, VITE_SUPABASE_ANON_KEY veya VITE_SUPABASE_PUBLISHABLE_KEY.
- Sentry entegrasyonu: production hata izleme için @sentry/react.
- Service worker, public headers, sitemap ve robots dosyaları.

3. Roller ve Yetki Mantığı

Sistem rolleri public.profiles.role alanından okunur. Frontend role değerine körü körüne güvenilmez; kritik işlemler Supabase RLS ve RPC içinde tekrar doğrulanır.

Rol	Erişim	Örnek İşlemler
customer	Kullanıcı uygulaması	Puan kazanma, mağaza, envanter, QR tarama, oyun, profil, destek

cashier	Kasa paneli	Alışveriş QR üretme, bilet/kupon sorgulama ve tek kullanımlık teslim
store_admin	Mağaza yönetimi	Mağaza ürünleri, QR, müşteri ve promosyon yönetimi
super_admin	Tam admin paneli	Kullanıcılar, ekonomi, ayarlar, günlük ödüller, oyunlar, etkinlikler, loglar

Önemli güvenlik yaklaşımı

Admin, kasiyer ve mağaza yönetimi route guard ile gizlenir; ancak asıl güvenlik veritabanındaki RLS/RPC katmanındadır. Kullanıcı frontend üzerinden rol değiştirerek kritik işlemleri geçemez.

4. Kullanıcı Sayfaları ve Özellikleri

Landing / Karşılama

- SEO odaklı tanıtım alanı, CTA butonları, kullanıcı yorumları, avantajlar ve marka sticker dili.
- Giriş ve ücretsiz kayıt yönlendirmeleri.
- Açık/koyu tema ve mobil uyumlu hero tasarım.

Login / Register

- E-posta/şifre ve Google OAuth giriş/kayıt.
- KVKK, Kullanım Şartları ve Gizlilik Politikası kabul akışı.
- PKCE auth callback; HashRouter uyumlu redirect.
- Yasaklı/silinmiş hesaplarda otomatik çıkış ve uyarı.

Ana Sayfa

- Puan bakiyesi, XP, seviye ilerlemesi ve level-up animasyonu.
- Sadakat limiti göstergesi: 75% üstünde Türkçe uyarı; limit dolunca büyük engel mesajı.
- Sıralama ve envanter kısa kartları, hızlı işlem kartları ve günlük giriş ödülü.
- Admin günlük ödül pasif yaparsa kullanıcıya gösterilmez.

Ödül Mağazası

- Supabase rewards tablosundan ürün listesi.
- Stok, sınırlı ürün, yetersiz puan, satın alınabilir ürün filtreleri.
- purchase_reward RPC ile atomik satın alma: puan düşer, bilet üretilir, stok azalır.
- Lazy image, decode async ve code-splitting ile scroll performansı.

Envanter

- Aktif, kullanılmış ve süresi dolmuş biletler.
- Bilet detayında QR ve kısa kod.
- expires_at üzerinden gerçek kalan süre ve progress bar.
- Kullanılan/expired bilet tekrar kullanılamaz.

QR Tarayıcı

- Kamera ile QR okuma ve manuel kod girişi.
- preview_qr_scan ile güvenli önizleme; claim_qr_scan ile tek kullanımlık claim.
- Manuel QR kodlar da tarama ile aynı backend doğrulamasından geçer.
- Limit, expiry, active, max_uses ve already_scanned kontrolleri server tarafında.

Liderlik

- Tüm zamanlar sıralaması, Top 3 podium ve liste sıralaması.
- Etkinlik liderliği: join_event sonrası event_participants tablosu.
- Gün/saat/dakika/saniye countdown ve ödül havuzu.
- Realtime sinyallerle kontrollü yenileme.

Mini Oyunlar

- Admin games_config üzerinden güncellenen oyun listesi.
- Tekrarlanan oyunları temizleyen DB/config mantığı.
- Oyun puan aralıkları, enabled/disabled durumu.
- Level-up animasyonu, ses ve partikül deneyimi.

Profil ve Ayarlar

- Kullanıcı bilgileri, toplam puan, başarı, mevcut puan, quick actions.
- Avatar editor: seed, ten rengi, gözlük varyantları.
- Kötü/+18 kelime uyarısı: profil kaydı kabul edilmez veya uyarılır.
- Bildirimler, geçmiş, gizlilik, şifre değiştirme, destek ve istatistik sayfaları.

5. Admin, Mağaza Admin ve Kasiyer Özellikleri

Süper Admin Dashboard

- Genel KPI kartları: kullanıcı, puan, ödül, QR, risk ve büyüme metrikleri.
- Panel V2, analitik grafikler, son aktiviteler ve sistem sağlığı.
- Mobil sidebar, tema ve güvenli çıkış.

Kullanıcı Yönetimi

- Profiles tablosundan kullanıcı listesi, arama, filtre ve detay.
- Puan hareketleri, rozet/görev/QR/envanter özetleri.
- Ban/unban ve hesap durumu işlemleri backend kontrolüyle.

Rol Yönetimi

- Rol işlemleri kullanıcı yönetimi içinde yürür.
- public.profiles.role kaynak alınır; metadata role bilgisine güvenilmez.
- Süper admin dışındaki rol yükseltmeleri RLS/RPC ile engellenir.

Ödül / Ürün Mağazası Yönetimi

- rewards tablosuna bağlı ürün CRUD.
- Başlık, açıklama, puan, stok, kategori, görsel, limited/featured/active kontrolü.
- Admin update RLS/policy ile korunur.

Ödül Etkinlikleri

- Etkinlik oluşturma, banner rengi, tarih aralığı, prize slotları ve winner dağıtımı.
- Inclusive bitiş tarihi ve canlı countdown.
- Kazananlar event puanına göre belirlenir.

QR & Kod Yöneticisi

- qr_codes tablosuna bağlı satın alma QRları, mağaza kodları ve envanter kodları.

- Aktif/pasif, tek kullanımlık, kullanım sayısı, süresi ve kod kopyalama.
- admin_create_store_qr ve create_cashier_qr güvenli RPC akışları.

Admin Envanter Yönetimi

- Kullanıcı seçimi ve redemptions kayıtlarını görüntüleme.
- Öğe ekleme, güncelleme, kullanıldı işaretleme, QR/kod gösterme.
- Süreli bilet ve kullanılmış bilet ayrımı.

Günlük Giriş Ödülleri

- daily_reward_config tablosundan 7 günlük takvim.
- Gün bazlı puan, özel gün, enabled/pasif kontrolü.
- claim_daily_streak RPC backend validation yapar.

Oyun Yönetimi

- games_config tablosundan oyun listesi.
- Oyun adı, açıklama, ikon, renk, max plays/day, max points/play ve enabled ayarı.
- Kullanıcı oyun sayfası admin değişikliklerini Supabase üzerinden görür.

Puan Ekonomisi ve Loyalty Settings

- Maksimum puan limiti varsayılan 1200.
- Puan limitini aç/kapat, max limit, ticket valid for ve unit dakika/saat/gün.
- Backend claim kontrolü: limit, current_points, expiry, enabled setting.

Bildirim, E-posta ve Destek

- Admin bildirim gönderimi, email Edge Function altyapısı.
- Push subscription kayıtları ve service worker.
- Support ticket listesi ve cevap/işlem akışı.

Kasiyer Paneli

- Alışveriş tutarından kazanılacak puanı hesaplar.
- Tek kullanımlık QR üretir; süreli, max_uses=1 ve cashier QR mantığı.
- Bilet/kupon kodunu manuel veya QR tarayıcı ile sorgular ve teslim eder.
- Kullanılmış/expired bilet tekrar kullanılamaz.

Mağaza Admin Paneli

- Mağaza dashboard, ürünler, rewards, inventory, promosyonlar, müşteriler, QR, bildirim ve analytics.
- Store admin rolü full super_admin panelinden ayrıştırılmıştır.

6. İş Mantığı

Puan Kazanma

Kullanıcı QR, günlük giriş, görev, oyun, achievement ve referral gibi aksiyonlardan puan kazanır. Frontend yalnızca aksiyon veya kod gönderir; gerçek puan hesabı RPC tarafında yapılır.

XP ve Seviye

Puan/aksiyon sonrası XP hesaplanır; level_config ve profile alanları kullanılarak seviye ilerlemesi güncellenir. Seviye artışında büyük overlay, ses, animasyon ve partikül deneyimi gösterilir.

Ödül Satın Alma

purchase_reward reward kaydını kilitler, kullanıcının puanını kontrol eder, puanı düşer, redemptions kaydı ve benzersiz kısa kod üretir, stok azaltır ve expires_at belirler.

Bilet Kullanımı

Kasiyer lookup_redemption_by_code ile bilgiyi görür, mark_redemption_used_by_code ile atomik olarak used=true ve used_at set eder. Expired veya used bilet reddedilir.

QR Claim

claim_qr_scan kodu normalize eder, aktiflik/süre/max use/already scanned kontrolü yapar, puanı işler, qr_scans kaydı oluşturur.

Sadakat Limiti

points_limit_enabled aktifse max_points_limit aşımı backendde engellenir. 75% altında kart gizli; 75% üstünde uyarı; 100% sonrası claim blok mesajı.

Günlük Ödül

daily_reward_config günlerine göre ödül hesaplanır. Aynı gün tekrar claim engellenir, seri günleri takip edilir, disabled config kullanıcıya kapatılır.

Etkinlik Sıralaması

Kullanıcı evente katıldıktan sonra event_participants üzerinden event puanı hesaplanır. get_event_leaderboard limitli veri döndürür ve realtime sinyallerle yenilenir.

7. Güvenlik Raporu

SQL Injection

Frontend Supabase query builder ve RPC parametreleri kullanıyor; string birleştirme ile SQL çalıştırma yok. Kritik SQL fonksiyonlarında p_code, p_reward_id, p_user_id gibi parametreler kullanılıyor.

RLS

profiles, redemptions, qr_codes, qr_scans, app_settings, daily_reward_config, games_config gibi tablolar RLS politikaları ile ayrılıyor.

Service Role Güvenliği

Frontend yalnızca anon/publishable key kullanır. Service role gerektiren işler Supabase Edge Function veya security definer RPC tarafında kalır.

Rol ve Privilege Escalation

Rol public.profiles.role alanından okunur. protect_profile_privileged_fields triggerı normal kullanıcıların role/status gibi ayrıcalıklı alanları doğrudan güncellemesini engeller.

QR Replay ve Double Spending

qr_scans kaydı, max_uses, uses_count, expires_at ve already scanned kontrolü ile QR tekrar kullanımı engellenir.

Bilet Double Spending

redemptions.used, used_at, expires_at ve mark_redemption_used_by_code atomik update ile aynı biletin ikinci kez teslimini engeller.

XSS

React default escaping kullanır. Kullanıcı metinleri JSX içinde düz text olarak render edilir; kritik kullanıcı alanlarında raw HTML yaklaşımı kullanılmaz.

IDOR

Kullanıcıya ait verilerde `user_id = auth.uid()` RLS yaklaşımı; cashier/admin çapraz erişimler ise role check yapan RPC ile sınırlandırılır.

Auth Redirect

PKCE flow, `authCallbackUrl` ve `HashRouter` uyumu kullanılır. Google OAuth redirect Supabase provider üzerinden yürür.

Kötü/+18 İçerik

`profile_has_adult_content` ve `moderate_profile_adult_content` migrationı +18 kelimeleri yakalar; profil kaydında uyarı/engelleme mantığı vardır.

LocalStorage / Session

Supabase auth session persist eder; logout sırasında `sb-*` localStorage anahtarları temizlenir. Rol değeri localStoragedan değil DB profilden alınır.

Rate ve Döngü Kontrolü

Event leaderboard RPC çağrılarında loading guard/cache mantığı ve subscription cleanup yaklaşımı tekrar eden istekleri engellemek için uygulanmıştır.

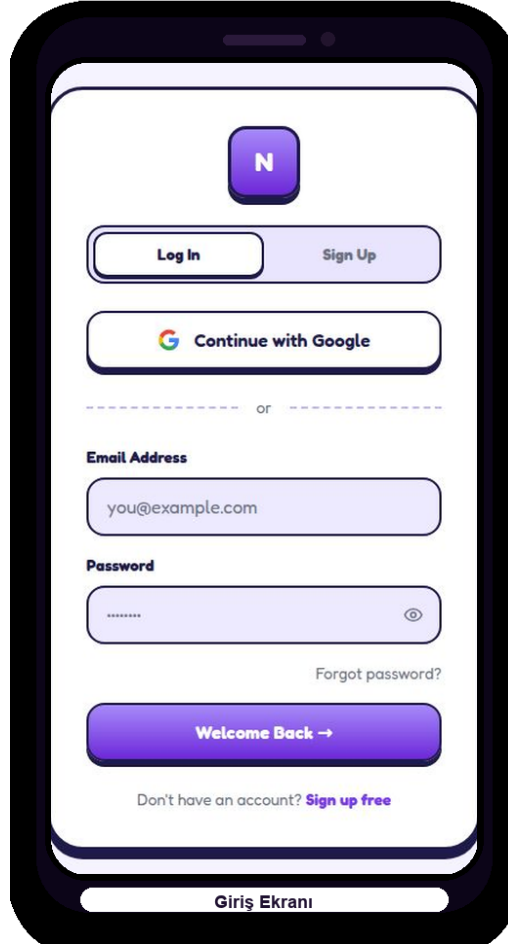
8. Sayfa Görselleri

Görsel 1: Karşılama / Landing



Karşılama / Landing

Görsel 2: Giriş Ekranı



A mobile app login screen mockup. At the top is a purple square logo with a white letter 'N'. Below it are two buttons: 'Log In' and 'Sign Up'. A 'Continue with Google' button with the Google logo is below that. A dashed line with 'or' in the center separates this from the email and password fields. The 'Email Address' field contains 'you@example.com'. The 'Password' field is masked with dots and has an eye icon. A 'Forgot password?' link is to the right of the password field. A large purple 'Welcome Back →' button is below. At the bottom, a link says 'Don't have an account? Sign up free'. The screen is framed by a black border.

N

Log In Sign Up

Continue with Google

or

Email Address

you@example.com

Password

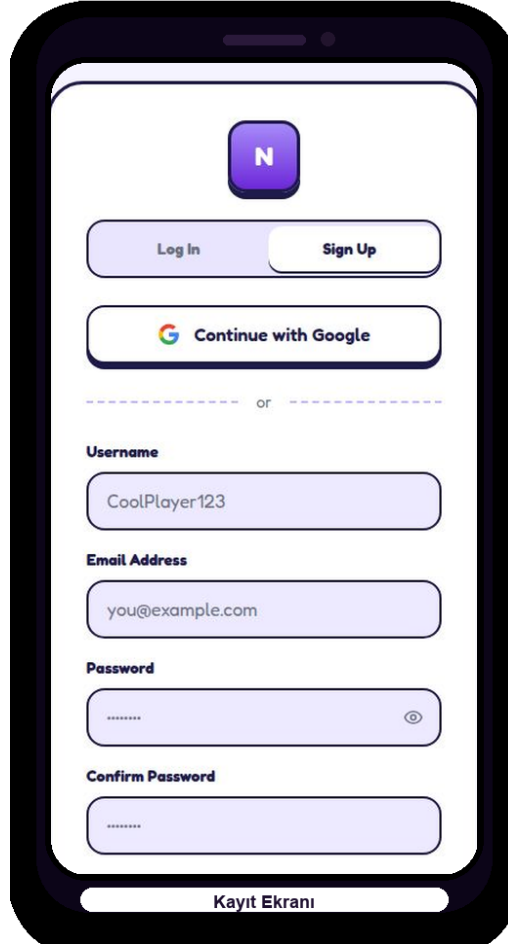
Forgot password?

Welcome Back →

Don't have an account? Sign up free

Giriş Ekranı

Görsel 3: Kayıt Ekranı



The image shows a mobile application registration screen. At the top, there is a purple square logo with a white letter 'N'. Below the logo, there are two buttons: 'Log In' and 'Sign Up'. The 'Sign Up' button is highlighted with a blue border. Below these buttons is a 'Continue with Google' button featuring the Google logo. A dashed line with the word 'or' in the center separates this from the registration fields. The registration fields are labeled 'Username', 'Email Address', 'Password', and 'Confirm Password'. The 'Username' field contains the text 'CoolPlayer123'. The 'Email Address' field contains 'you@example.com'. The 'Password' and 'Confirm Password' fields are masked with dots and each has a small eye icon to toggle visibility. At the bottom of the screen, there is a white bar with the text 'Kayıt Ekranı'.

N

Log In Sign Up

Continue with Google

or

Username

CoolPlayer123

Email Address

you@example.com

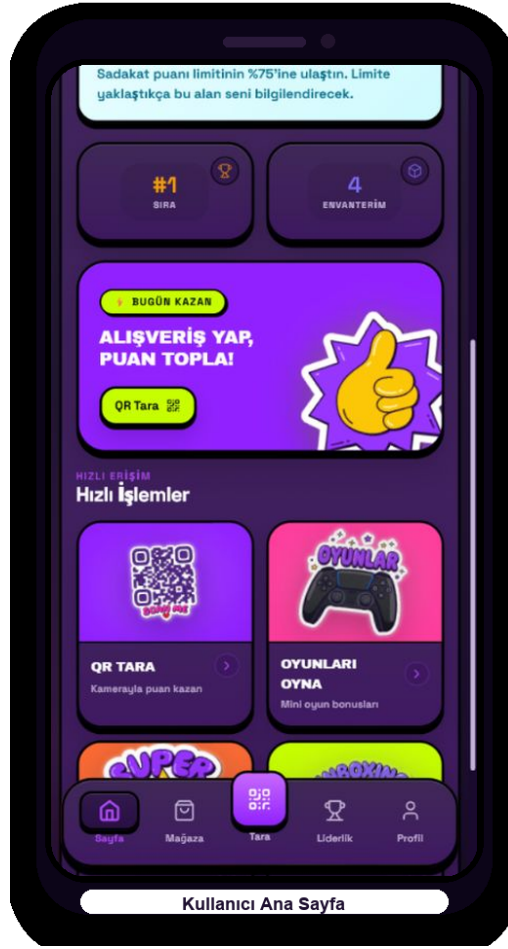
Password

Confirm Password

Kayıt Ekranı

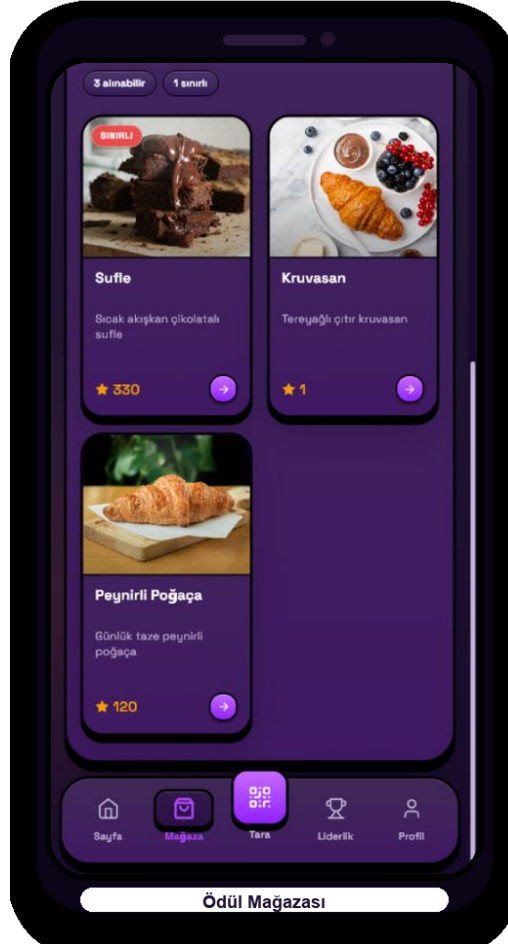
Kayıt Ekranı

Görsel 4: Kullanıcı Ana Sayfa



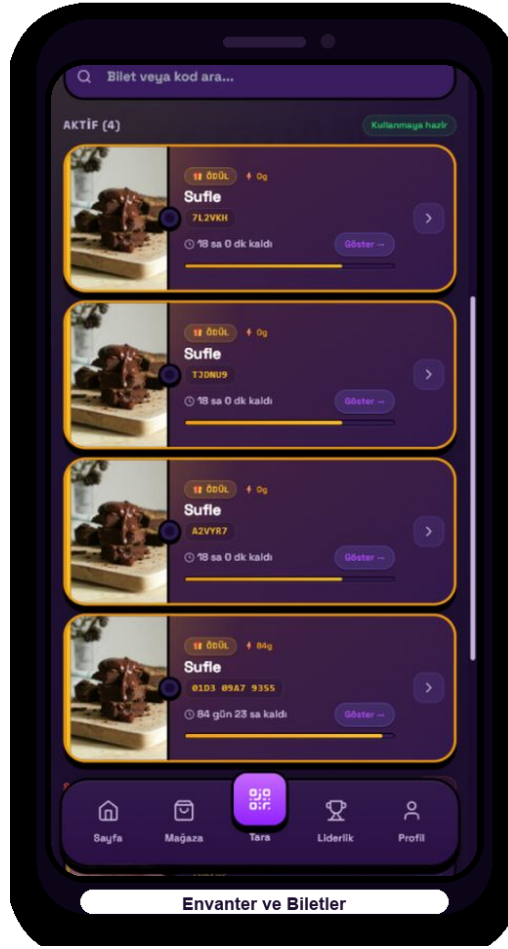
Kullanıcı Ana Sayfa

Görsel 5: Ödül Mağazası



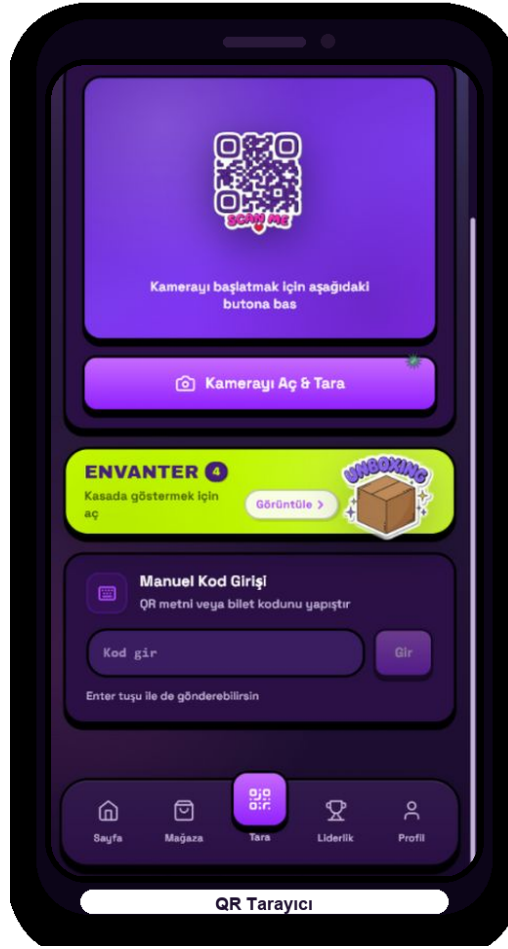
Ödül Mağazası

Görsel 6: Envanter ve Biletler



Envanter ve Biletler

Görsel 7: QR Tarayıcı



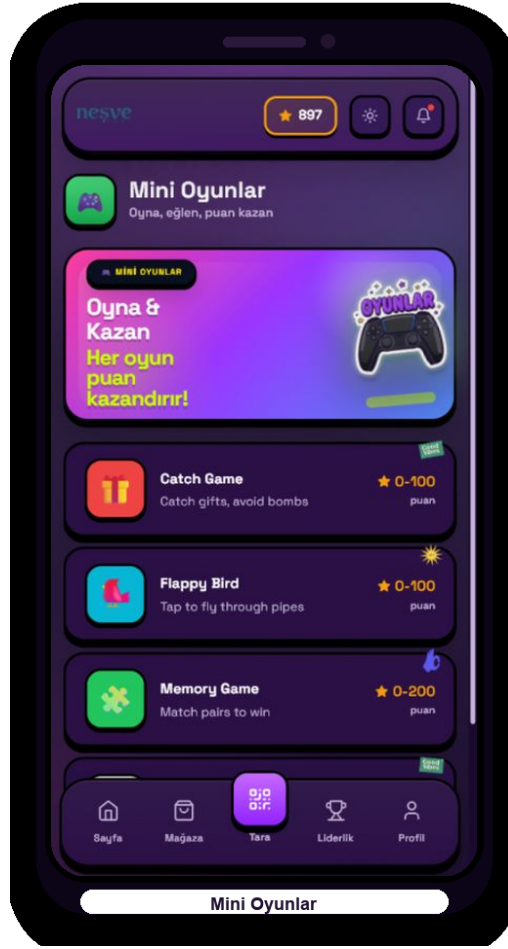
QR Tarayıcı

Görsel 8: Liderlik ve Etkinlik



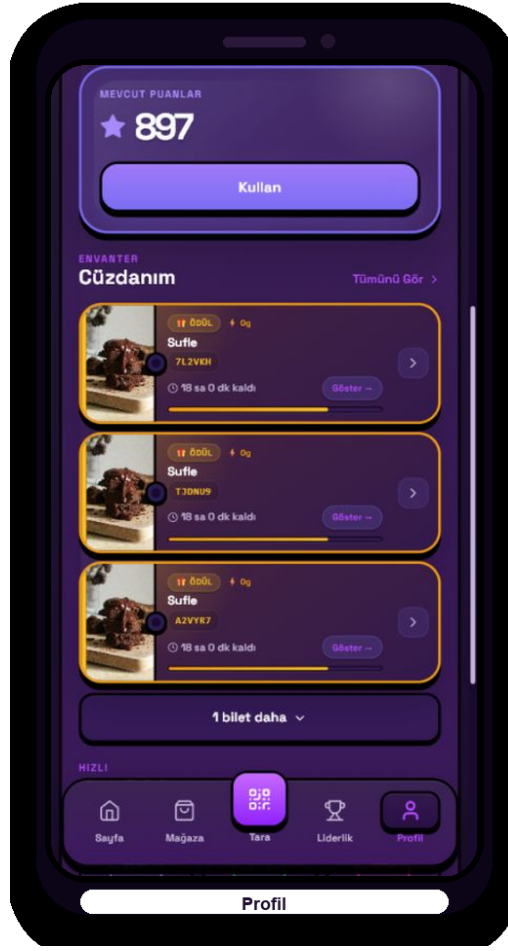
Liderlik ve Etkinlik

Görsel 9: Mini Oyunlar



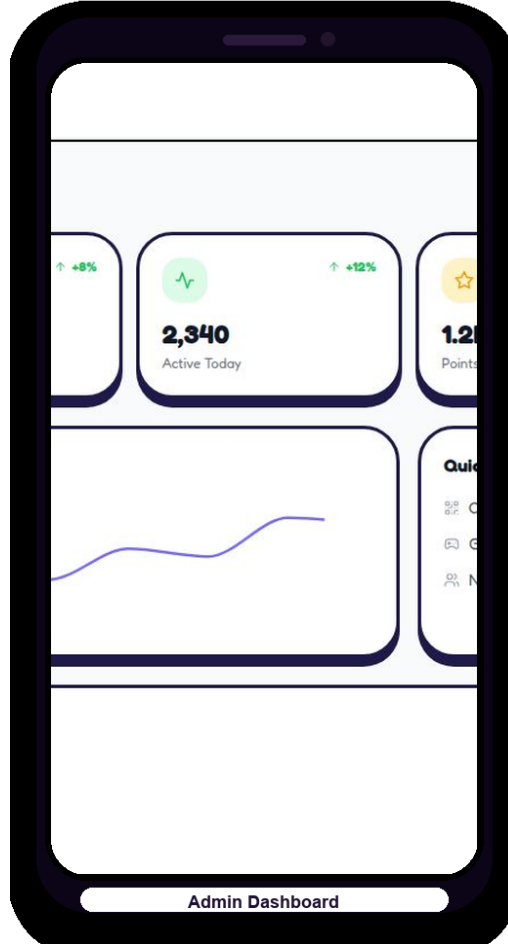
Mini Oyunlar

Görsel 10: Profil



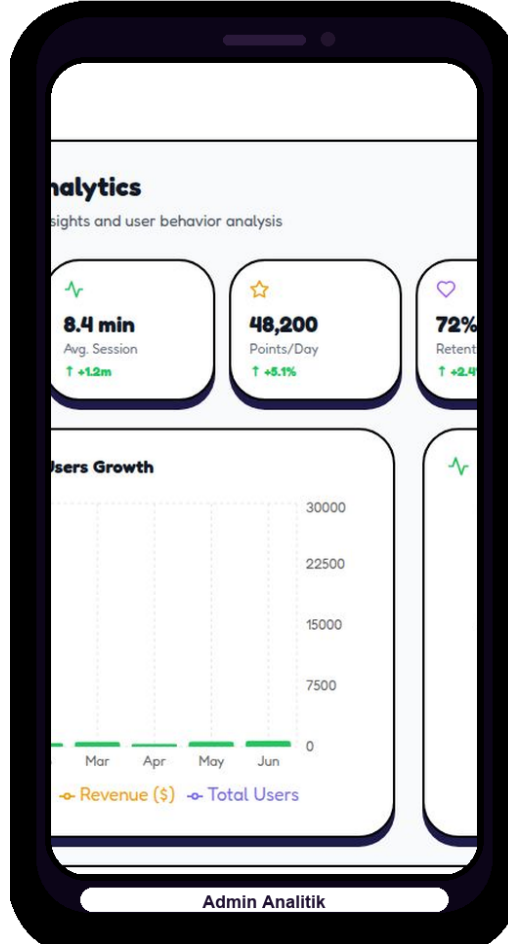
Profil

Görsel 11: Admin Dashboard



Admin Dashboard

Görsel 12: Admin Analitik



Admin Analitik

9. Teknik Dosya Haritası

Alan	Dosyalar / Klasörler	Açıklama
Route ve shell	src/App.tsx, src/components/Layout.tsx	Public, customer, admin, store-admin ve cashier route ayrımı.
Auth	src/context/AuthContext.tsx, src/lib/supabase.ts	Session, profile role fetch, Google OAuth, logout cleanup.
Puan/claim	src/services/earn.ts, src/services/points.ts	perform_action, claim_qr_scan, claim_daily_streak, leaderboard refresh.
Ödül/envanter	src/services/rewards.ts, src/services/redemptions.ts, src/context/InventoryContext.tsx	Reward CRUD, satın alma, redemptions, realtime envanter.
Admin	src/pages/admin/*, src/services/admin.ts	Dashboard, kullanıcılar, rewards, QR, inventory, günlük ödül, ayarlar.
Kasiyer	src/pages/admin/cashier/*	QR üretme, ticket redeem, geçmiş ve kasa akışı.
DB güvenliği	supabase/migrations/*.sql	RLS, RPC, triggers, claim limit, ticket timer, event ranking.

10. Mevcut Route Listesi

/, /landing, /login, /register, /auth/callback, /app, /home, /profile, /inventory, /shop, /games, /progress, /qr, /achievements, /missions, /notifications, /history, /settings, /settings/edit-profile, /settings/privacy, /settings/change-password, /support, /support/live-chat, /support/email, /support/call, /events, /leaderboard, /stats, /admin, /admin/dashboard-v2, /admin/analytics, /admin/users, /admin/rewards, /admin/reward-events, /admin/events, /admin/notifications, /admin/inventory, /admin/checkout, /admin/qr, /admin/games, /admin/missions, /admin/daily-rewards, /admin/points-economy, /admin/audit-logs, /admin/settings, /admin/support, /store-admin, /store-admin/items, /store-admin/rewards, /store-admin/inventory, /store-admin/promotions, /store-admin/customers, /store-admin/qr, /store-admin/notifications, /store-admin/analytics, /cashier, /cashier/scan, /cashier/redeem, /cashier/history

11. Kabul Kriterleri ve Son Kontrol Listesi

- Kullanıcı puan claim akışları server-side RPC ile doğrulanır.
- Maksimum sadakat limiti ve ticket geçerlilik süresi admin ayarlarından yönetilebilir.
- Expired ticket kullanıcı ve kasiyer akışında kullanılamaz.
- QR ve bilet kodları tek kullanımlık/replay korumalıdır.
- Admin/kasiyer yetkileri frontend rolüne değil Supabase role/RLS/RPC doğrulamasına dayanır.
- Kullanıcı dashboardu limit yakınlığını Türkçe ve 75% üstünde gösterir.
- Günlük ödül admin pasif olduğunda kullanıcı sayfasında görünmez.
- Oyun, QR, inventory, rewards ve daily reward sayfaları Supabase verisine bağlıdır.
- Google OAuth ve e-posta auth PKCE/HashRouter uyumlu çalışır.
- Production build Vite dist üretir; Vercel outputDirectory project/dist olarak ayarlanır.

12. Önerilen Sonraki İyileştirmeler

- Admin ekranları için ayrı e2e smoke test: super_admin, cashier ve customer rolleriyle route erişimi kontrolü.
- QR claim ve ticket redeem fonksiyonları için pgTAP veya Supabase SQL test seti.
- Store page ürün gridinde virtualization veya viewport bazlı image priority ile daha da akıcı scroll.
- Kötü kelime filtresinin Türkçe/İngilizce varyasyonları ve normalize edilmiş karakter eşlemeleriyle genişletilmesi.
- Audit log panelinde yüksek riskli işlem bildirimleri ve admin değişiklik geçmişi exportu.
- Raporun şirket sunumu için Canva/PPT versiyonu.